

# Business Requirements Document

## Multi-Tenant Hostel Check-In / Check-Out Web App

Version 1.0 · Owner: Product · Status: Draft for build

### 1. Executive summary

A responsive, multi-tenant web app that lets independent hostels (private rooms + dorm beds) run their entire guest lifecycle — discovery, booking, KYC, check-in, in-stay requests/complaints with tracked SLAs, checkout, feedback — while giving guests a "verify once, stay anywhere" experience with privacy-preserving profile sharing across properties.

**\*\*Primary users:\*\*** Backpackers and budget travellers (mobile-first), hostel managers/staff (mobile + desktop), property owners (desktop), platform operator (desktop).

**\*\*Business model:\*\*** SaaS subscription per property (Starter / Growth / Scale) with optional per-transaction fee on bookings routed via the platform.

**\*\*Success metrics (v1, 6 months post-launch):\*\***

- 50 active properties
- 60% of bookings from returning verified guests (KYC reuse rate)
- Median request-to-resolution < 30 min
- Staff ack-rate for assigned tasks > 95% within 5 min
- App Lighthouse Perf  $\geq 90$  on mobile

### 2. Scope & non-goals

#### *In scope for v1*

- Multi-tenant SaaS with strong tenant isolation (Postgres RLS + `tenant\_id`).
- Roles: Super Admin, Property Admin, Manager, Staff, Customer, Customer Dependent.
- Phone-OTP login (India + international via libphonenumber-js and Firebase Phone Auth, MSG91 fallback for cost).
- KYC-once vault (Aadhaar masked / Passport / DL / Voter ID) with encrypted storage in GCS + CMEK; portable verification with explicit per-tenant consent.
- Dorm-bed and private-room inventory, calendar-based availability, walk-in support.
- Payments via Razorpay (IN) and Stripe (intl) — abstracted `PaymentProvider`.
- Real-time request & complaint pipeline with mandatory ETA and live progress bar for guest.
- Notifications: push (FCM/Web Push), SMS fallback (MSG91/Twilio), email (SendGrid), in-app.
- Feedback with anonymous sharing to future properties + special-request handoff.
- Reports per property (occupancy, ADR, NPS, SLA on-time %).
- PWA with offline task queue for staff.

- Automated CI/CD to Cloud Run via GitHub Actions.

### Non-goals for v1

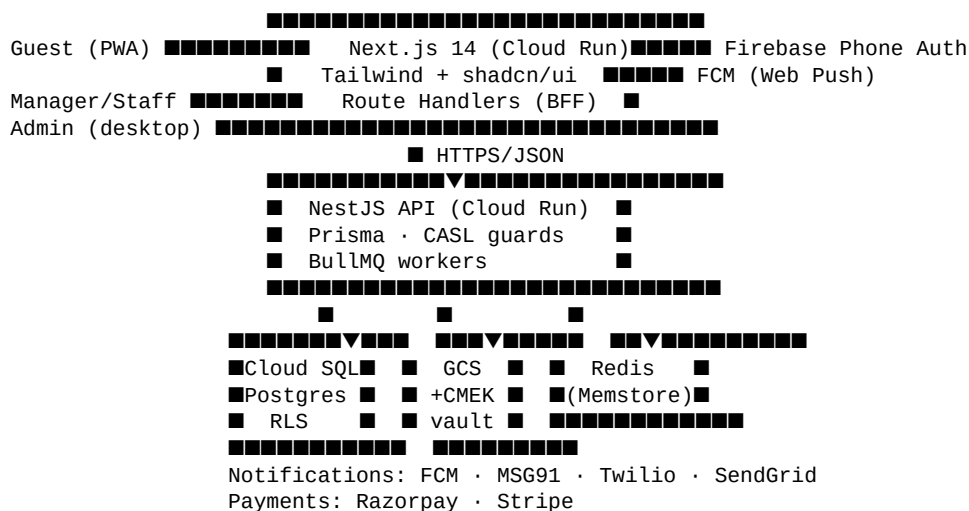
- Native iOS/Android apps (PWA is the mobile surface).
- POS / food & beverage.
- Housekeeping supplies inventory.
- Dynamic pricing AI.
- Loyalty / rewards program.
- In-app voice / video calls.
- OTA channel-manager sync (Booking.com, Hostelworld) — v2 stub only.
- Multi-currency FX (each property invoices in its local currency).

## 3. User roles & permissions

| Role                          | Scope                             | Key permissions                                                                  |
|-------------------------------|-----------------------------------|----------------------------------------------------------------------------------|
| <b>**Super Admin**</b>        | Platform                          | Onboard/suspend tenants, feature flags, KYC provider config, revenue, manual KYC |
| <b>**Property Admin**</b>     | One tenant (may own N properties) | Property config, pricing, staff & roles, integrations, GST, billing              |
| <b>**Manager**</b>            | One property                      | Bookings, check-in/out, requests, complaints, staff assignment, ETAs, reports    |
| <b>**Staff**</b>              | One property                      | Assigned task inbox; acknowledge → in-progress → done; photo proof               |
| <b>**Customer (Primary)**</b> | Own profile + own bookings        | KYC, bookings, requests, feedback, dependents                                    |
| <b>**Customer Dependent**</b> | Attached to primary's booking     | View shared booking, raise scoped requests                                       |

Permission matrix implemented as CASL abilities in FE and NestJS guards in BE.

## 4. High-level architecture



See `diagrams/architecture.png`, `diagrams/er.png`, and the four sequence diagrams.

## 5. Tech stack (locked)

### **\*\*Frontend (`checkin-fe`)\*\***

- Next.js 14 (App Router, React Server Components)
- TypeScript strict
- Tailwind CSS + shadcn/ui + Radix
- next-pwa (offline for staff)
- TanStack Query for client cache
- Zod for validation
- next-intl (EN, HI initial)
- Playwright for E2E, Vitest for unit

### **\*\*Backend (`checkin-be`)\*\***

- NestJS 10 (TypeScript strict)
- Prisma ORM
- Postgres 15 (Cloud SQL)
- BullMQ (Redis) for jobs — SLA timers, notifications, escalations
- CASL for authorization
- Pino logging → Cloud Logging
- OpenAPI/Swagger auto-generated
- Jest for unit, Supertest for integration

### **\*\*Auth\*\***

- Firebase Phone Auth (issues Firebase ID token) → BE verifies via `firebase-admin` and mints its own session JWT with tenant + role claims.

### **\*\*Infra\*\***

- Cloud Run (FE + BE, autoscale to zero)
- Cloud SQL Postgres (start db-f1-micro, scale up)
- Memorystore Redis (0.5 GB dev)
- GCS bucket `ids-vault-<env>` with CMEK, uniform bucket-level access, retention policy 7y, signed URLs only
- Secret Manager for all secrets
- Cloud Scheduler → HTTP task for daily rollups
- Artifact Registry for images
- Cloud Logging + Error Reporting

### **\*\*Notifications\*\***

- FCM (web push) — free
- MSG91 (India SMS) primary, Twilio (intl SMS) fallback
- SendGrid (email) free tier

## **\*\*Payments\*\***

- Razorpay (IN default), Stripe (intl)

## **\*\*Why this stack fits GCP \$300 credit\*\***

Cloud Run scales to zero; Cloud SQL micro tier ~\$8/mo; GCS pennies; FCM free; Redis dev tier ~\$25/mo (can start without Redis — use in-memory Bull for dev). Estimated dev burn ≈ \$30–50/mo.

## **6. Data model (Prisma-flavored, abbreviated)**

Full schema lives in ``04_Repo_Scaffolds/checkin-be/prisma/schema.prisma``. Highlights:

- ``Tenant`` (property owner / SaaS customer)
- ``Property`` (belongs to Tenant; one Tenant may have many Properties)
- ``RoomType`` (dorm / private) — belongs to Property
- ``Room`` — belongs to RoomType
- ``Bed`` — belongs to Room (nullable for private rooms treated as single-bed)
- ``User`` (all humans; discriminated by ``role`` and ``tenantId``)
- ``CustomerProfile`` (global — one per phone, not tenant-scoped)
- ``Dependent`` (belongs to CustomerProfile)
- ``KycDocument`` (belongs to CustomerProfile; encrypted GCS URI + hash)
- ``KycConsent`` (per-tenant grant referencing KycDocument)
- ``Booking`` (Property + CustomerProfile; child ``BookingGuest`` rows for primary + dependents; ``BookingBed`` rows for assigned beds)
- ``Request`` (in-stay: category, priority, state machine)
- ``Complaint`` (similar; separate SLA)
- ``ServiceEvent`` (state transitions with ``actorId``, ``etaMinutes``, ``photoUri``)
- ``Feedback`` (Booking → Property; ``anonymousShare`` bool)
- ``SpecialRequest`` (per Booking; portable to future properties)
- ``Payment`` / ``Invoice``
- ``AuditLog`` (append-only)
- ``Notification`` (per user; delivery-channel breakdown)

**\*\*Multi-tenancy:\*\*** every tenant-scoped table has ``tenantId``. Postgres RLS enforced on every request via ``SET LOCAL app.tenant_id``. Global tables (``CustomerProfile``, ``KycDocument``) are read only by their owner unless a ``KycConsent`` row grants a tenant.

## **7. Complete page inventory**

Numbers align with wireframe filenames in ``02_Wireframes/by-role/``.

### **7.1 Customer (mobile PWA) — 42 pages**

01 Splash · 02 Phone-OTP login · 03 OTP verify · 04 OTP failed · 05 Profile create · 06 KYC intro · 07 KYC upload · 08 KYC selfie liveness · 09 KYC in-review · 10 KYC verified · 11 KYC rejected · 12 Home dashboard · 13 Search · 14 Search results · 15 Property detail · 16 Room/bed picker · 17 Dates · 18 Guests + dependents · 19 Add dependent · 20 Special requests · 21 Review & pay · 22 Payment processing · 23 Payment failed · 24 Booking confirmed · 25 Upcoming list · 26 Check-in live (housekeeping progress) · 27 Digital pass QR · 28 In-stay home · 29 Raise request · 30 Request tracking with live ETA · 31 Complaint · 32 Chat with staff · 33 Invoice · 34 Checkout · 35 Feedback · 36 Feedback history · 37 ID vault · 38 Dependents · 39 Notifications · 40 Consent & sharing · 41 Delete account · 42 Help/policies

### **7.2 Dependent (mobile) — 8 pages**

01 Invite accept · 02 Profile · 03 Shared booking · 04 In-stay · 05 Request · 06 Notifications · 07 Remove self · 08 Help

### **7.3 Staff (mobile PWA offline) — 15 pages**

01 Sign in · 02 Today dashboard · 03 Task detail · 04 Set ETA · 05 In-progress · 06 Mark done · 07 Escalate · 08 Schedule · 09 Room-status board · 10 Lost & found · 11 Notifications · 12 Profile · 13 Offline queue · 14 Missed-ack (auto-escalated) · 15 Complaint assigned

### **7.4 Manager (mobile + desktop) — 25 pages**

01 Sign in · 02 Dashboard · 03 Arrivals · 04 Walk-in · 05 Reuse verified ID · 06 Assign bed · 07 Digital pass issue · 08 Checkout · 09 Bill adjust · 10 Requests kanban · 11 Assign staff · 12 Set ETA · 13 Complaints board · 14 Prior anonymized feedback · 15 Special requests · 16 Housekeeping board · 17 Rates & inventory · 18 Dorm bed map · 19 Private rooms · 20 Reports · 21 Audit log · 22 Staff mgmt · 23 Notifications · 24 Settings · 25 No-show

### **7.5 Property Admin (desktop) — 20 pages**

01 Sign in · 02 Overview · 03 Property profile · 04 Media · 05 Room types · 06 Dorm layout · 07 Pricing rules · 08 Taxes · 09 Policies · 10 Cancellation matrix · 11 Staff & roles · 12 Shift templates · 13 Notification templates · 14 Payment gateway · 15 Invoices/GST · 16 Reports export · 17 Integrations · 18 API keys · 19 Audit · 20 Platform billing

### **7.6 Super Admin (desktop) — 12 pages**

01 Sign in · 02 Tenants · 03 Onboard tenant · 04 Plans · 05 Feature flags · 06 Platform metrics · 07 Incidents · 08 Notification templates library · 09 KYC provider config · 10 Manual KYC queue · 11 Abuse reports · 12 Revenue

### **7.7 Shared — 6 pages**

404 · 500 · Maintenance · Offline · Permission denied · Session expired

\*\*Total: 128 screens.\*\*

## **8. Core workflows (state machines)**

### **8.1 Booking**

`DRAFT → PAYMENT\_PENDING → CONFIRMED → CHECKED\_IN → CHECKED\_OUT → CLOSED`

Side branches: `CANCELLED\_BY\_GUEST`, `CANCELLED\_BY\_PROPERTY`, `NO\_SHOW`, `OVERSTAY`.

## 8.2 KYC

`PENDING` → `PROVIDER\_VERIFYING` → `APPROVED` / `REJECTED` → `EXPIRED`

Re-use: on new booking at a new property, if `KycDocument.status` = `APPROVED` and not expired, prompt guest to grant `KycConsent`. Manager sees "verified via vault" badge.

## 8.3 Request / Complaint

`NEW` → `ACKNOWLEDGED` → `ASSIGNED` → `IN\_PROGRESS` → `RESOLVED` → `CONFIRMED\_BY\_GUEST`

Side: `REOPENED`, `ESCALATED`, `AUTO\_ESCALATED\_ON\_MISS`.

**\*\*SLA rules:\*\***

- Ack within 5 min of assignment (staff). Miss → auto-escalate to manager + persistent banner.
- Manager **MUST** enter `etaMinutes` before state can move past `ACKNOWLEDGED`.
- Guest sees live progress bar computed from `assignedAt + etaMinutes`.
- Complaint SLA is tighter: 3 min ack, mandatory manager review at each transition.

## 8.4 Check-in

Two paths: **\*\*digital\*\*** (guest arrives with QR) and **\*\*walk-in\*\*** (manager creates booking on the spot). Both:

1. Verify identity (vault reuse or fresh upload).
2. Assign bed.
3. Issue digital pass (QR + optional door PIN).
4. Send arrival notification to housekeeping if room not ready.

## 8.5 Check-out

1. Manager reviews balance, damages, late fees.
2. Guest confirms via app (or manager confirms on their behalf).
3. Invoice generated, sent by email/SMS.
4. Feedback prompt sent 30 min later.
5. Bed marked `DIRTY`; housekeeping task auto-created.

## 9. Notification matrix

| Event                        | Customer              | Dependent | Staff | Manager                   | P. |
|------------------------------|-----------------------|-----------|-------|---------------------------|----|
| Booking created              | 📧 push+SMS            | —         | —     | 📧 push                    | —  |
| Payment success              | 📧 push+SMS+email(inv) | 📧 push    | —     | 📧 push                    | —  |
| Payment failed               | 📧 push+SMS            | —         | —     | 📧 push                    | —  |
| KYC approved                 | 📧 push                | —         | —     | 📧 (if pending on booking) | —  |
| KYC rejected                 | 📧 push+SMS            | —         | —     | —                         | —  |
| Check-in window opens (T-2h) | 📧 push+SMS            | 📧 push    | —     | 📧                         | —  |
| Bed ready                    | 📧 push+SMS            | 📧 push    | —     | 📧                         | —  |
| Digital pass issued          | 📧 push                | 📧 push    | —     | —                         | —  |

|                          |                   |                    |                               |                         |                  |
|--------------------------|-------------------|--------------------|-------------------------------|-------------------------|------------------|
| Request created          | 📧 push            | 📧 push (if shared) | —                             | 📧 push+SMS              | —                |
| Request assigned         | 📧 push (with ETA) | 📧 push             | 📧 push+SMS(persistent)        | 📧 push                  | —                |
| Staff misses ack (5m)    | —                 | —                  | ■ persistent banner + re-ping | 📧 push+SMS URGENT       | —                |
| ETA changed              | 📧 push            | 📧 push             | 📧 push                        | —                       | —                |
| Request resolved         | 📧 push            | 📧 push             | —                             | 📧 push                  | —                |
| Guest reopens            | —                 | —                  | 📧 push+SMS                    | 📧 push+SMS              | —                |
| Complaint filed          | 📧 push (ack)      | —                  | —                             | 📧 push+SMS+email URGENT | 📧 push+SMS+email |
| Complaint escalated      | 📧 push            | —                  | 📧 push+SMS                    | 📧 push+SMS              | 📧 push+SMS+email |
| SLA breach               | —                 | —                  | —                             | 📧 push+SMS URGENT       | 📧 push+SMS+email |
| Checkout reminder (T-1h) | 📧 push+SMS        | 📧 push             | —                             | —                       | —                |
| Overstay                 | 📧 push+SMS        | —                  | —                             | 📧 push+SMS              | —                |
| No-show                  | 📧 push+SMS        | —                  | —                             | 📧 push                  | —                |
| Feedback prompt          | 📧 push+email      | 📧 push             | —                             | —                       | —                |
| Refund issued            | 📧 push+SMS+email  | —                  | —                             | 📧                       | 📧 push+SMS+email |
| Incident (P1/P2)         | —                 | —                  | —                             | 📧 push                  | 📧 push+SMS+email |
| Tenant suspended         | —                 | —                  | 📧 email                       | 📧 email                 | 📧 push+SMS+email |

Delivery channels are configurable per template by Super Admin and Property Admin (with platform-level minimums that can't be turned off — e.g., payment receipts).

## 10. Security & privacy

### 10.1 ID handling (KYC vault)

- Files stored in GCS bucket `ids-vault-<env>`, uniform bucket-level access, CMEK with a rotating key in Cloud KMS.
- File name is `sha256(userId + originalName + salt)`; no PII in path.
- Access only via short-lived (5-min) signed URLs, generated after CASL check.
- **Aadhaar masking:** we NEVER store the raw 12-digit number. We store a masked image (last 4 visible) per UIDAI guidelines. Manual review queue can view unmasked only if `KycConsent.reason = "govt\_registration"` and audit-log entry created.
- 7-year retention (Indian hotel guest register rule), then hard delete.
- On DPDP right-to-erasure request, files are deleted; audit log retains hash only.

### 10.2 Multi-tenant isolation

- Every request has `X-Tenant-Id` header (from session JWT). NestJS interceptor runs `SET LOCAL app.tenant\_id = \$1` at start of each Prisma transaction; Postgres RLS policies enforce `tenant\_id = current\_setting('app.tenant\_id')::uuid` on every tenant-scoped table.
- Cross-tenant queries (Super Admin only) use a special `service\_role` connection that bypasses RLS.

### 10.3 Auth

- Firebase Phone Auth for OTP delivery only; BE verifies `idToken` server-side and issues its own signed JWT (HS256, rotating secret in Secret Manager) with claims `{ sub, role, tenantId?, propertyId? }`.
- Session lifetime 30 days, refresh token 90 days, both httpOnly SameSite=Lax cookies.
- Rate-limit: 5 OTP requests / phone / hour; 10 verify attempts / phone / hour.

## 10.4 Legal

- **DPDP Act 2023 (India):** privacy notice, purpose limitation, consent artefacts stored, DPO email visible, grievance officer.
- **GDPR (EEA guests):** lawful basis = contract / legitimate interest / consent; right to access, rectification, erasure, portability.
- **Indian hotel guest register:** name, address, arrival/departure, ID type, ID number (masked), signature — auto-populated from booking; C-Form for foreign guests exportable.
- **PCI-DSS:** we never touch raw card data — all card entry via Razorpay/Stripe iframes; SAQ-A compliance.
- Anonymous feedback sharing: only aggregated star + free-text stripped of names, phone, email, dates by NER (using a local spaCy pipeline in a worker).

## 10.5 Input validation

- Zod schemas on both FE and BE for every endpoint.
- SQL is only via Prisma (no raw).
- HTML never dangerouslySet with user content.

# 11. Non-functional requirements

- **Performance:** p95 API < 300 ms, TTFB < 800 ms on 4G, Lighthouse mobile ≥ 90.
- **Availability:** 99.9% monthly (Cloud Run multi-instance + Cloud SQL HA on Growth+ plan).
- **Scalability:** designed for 500 properties / 50k MAU without re-architecture.
- **Accessibility:** WCAG 2.1 AA. Focus rings, semantic HTML, all forms label-associated, contrast ≥ 4.5:1.
- **Localization:** EN + HI at launch; strings via next-intl; RTL-ready CSS logical props.
- **Observability:** structured JSON logs, request IDs, Cloud Trace, Sentry for FE.
- **Backup:** Cloud SQL PITR 7 days; GCS versioning on vault bucket.

# 12. CI/CD

Two GitHub Actions workflows (in each repo):

1. `pr.yml` — lint, typecheck, unit tests, build.
2. `deploy.yml` — on merge to `main`: build Docker → push to Artifact Registry → deploy to Cloud Run (staging), run smoke tests, manual approval → prod.

Prisma migrations run as a one-shot Cloud Run job before BE deploys.



## 13. Milestones

| Sprint | Deliverable                                                       |
|--------|-------------------------------------------------------------------|
| S1     | Repos, CI/CD, GCP infra, auth (phone OTP), tenant + property CRUD |
| S2     | Customer profile + KYC vault + reuse consent                      |
| S3     | Booking flow (search → pay → confirm), inventory model            |
| S4     | Check-in/out, digital pass, walk-in                               |
| S5     | Request + complaint pipeline with SLA + live ETA progress         |
| S6     | Notifications (FCM + SMS + email) + templates                     |
| S7     | Manager dashboards, reports, staff PWA offline                    |
| S8     | Property Admin config surface, Super Admin, billing               |
| S9     | Hardening, WCAG audit, load test, beta launch                     |

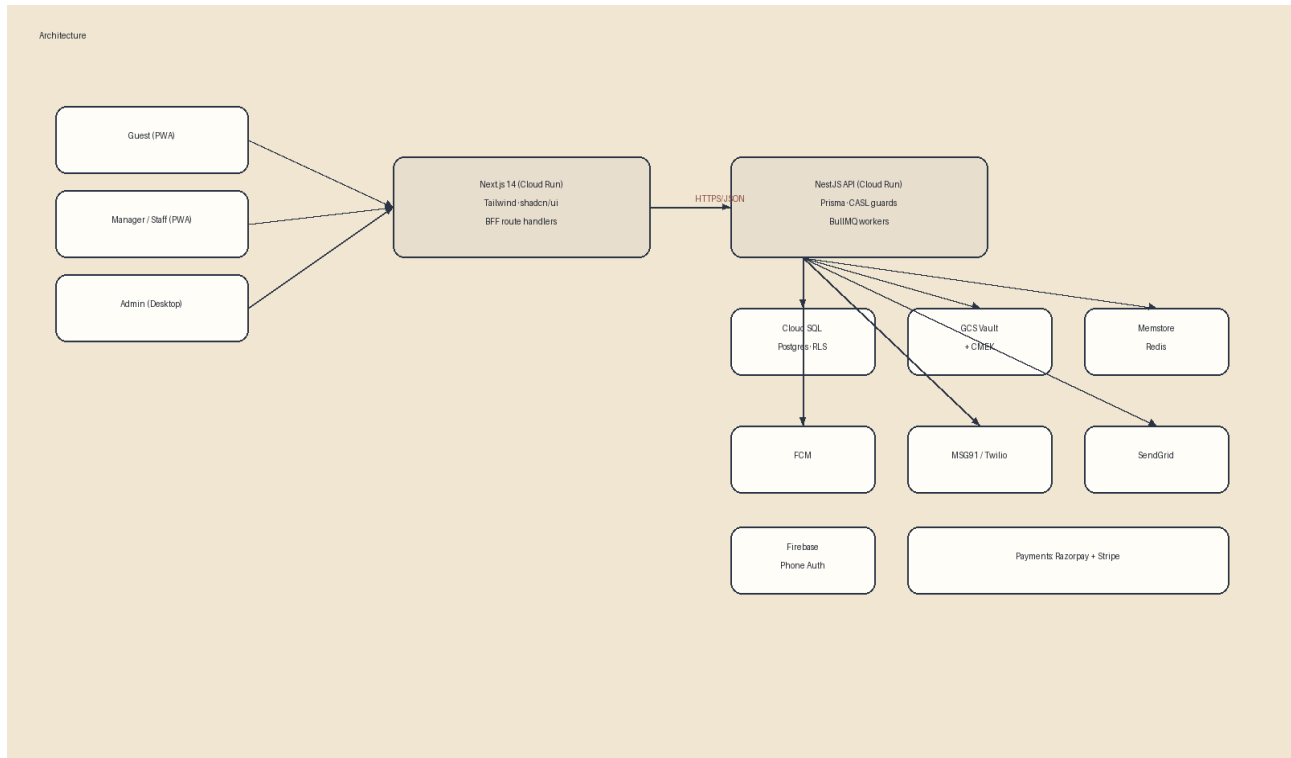
## 14. Open items (confirm before build)

1. Payment: Razorpay-first vs Stripe-first? BRD assumes Razorpay-first, Stripe intl fallback.
2. KYC provider: Digio / Signzy / Hyperverge / manual-only? BRD assumes `KycProvider` interface with manual review as safety net.
3. OTA channel-manager sync: v1 or v2? BRD assumes v2 stub.
4. SaaS platform billing at v1 (Super Admin ↔ Property Admin): included as Stripe subscription.

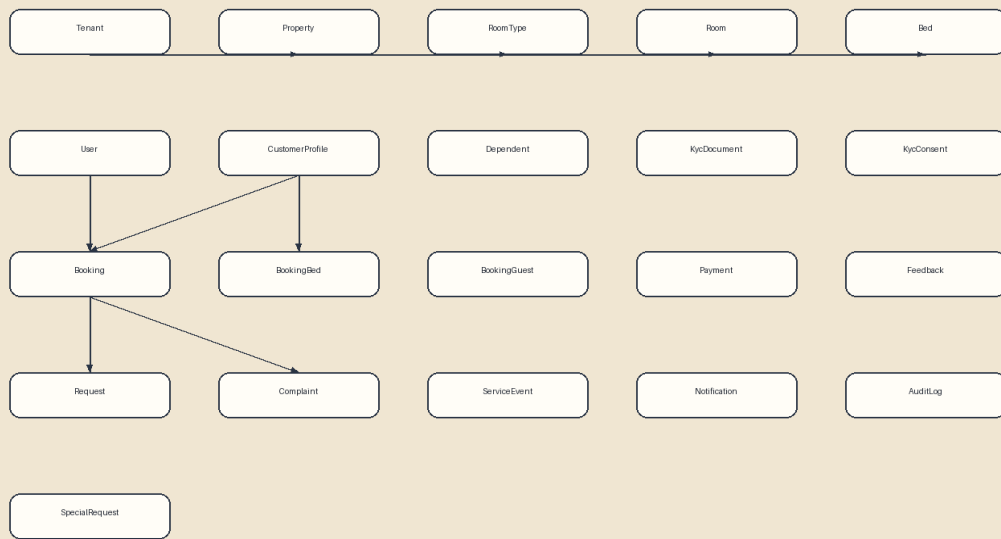
## 15. Appendix

- Diagrams: `diagrams/architecture.png`, `diagrams/er.png`, `diagrams/seq-checkin.png`, `diagrams/seq-complaint-eta.png`, `diagrams/seq-kyc-reuse.png`, `diagrams/seq-checkout.png`.
- Full page-by-page wireframes: `../02\_Wireframes/index.pdf`.
- Antigravity handoff prompt: `../03\_Antigravity\_Prompt/MASTER\_PROMPT.md`.

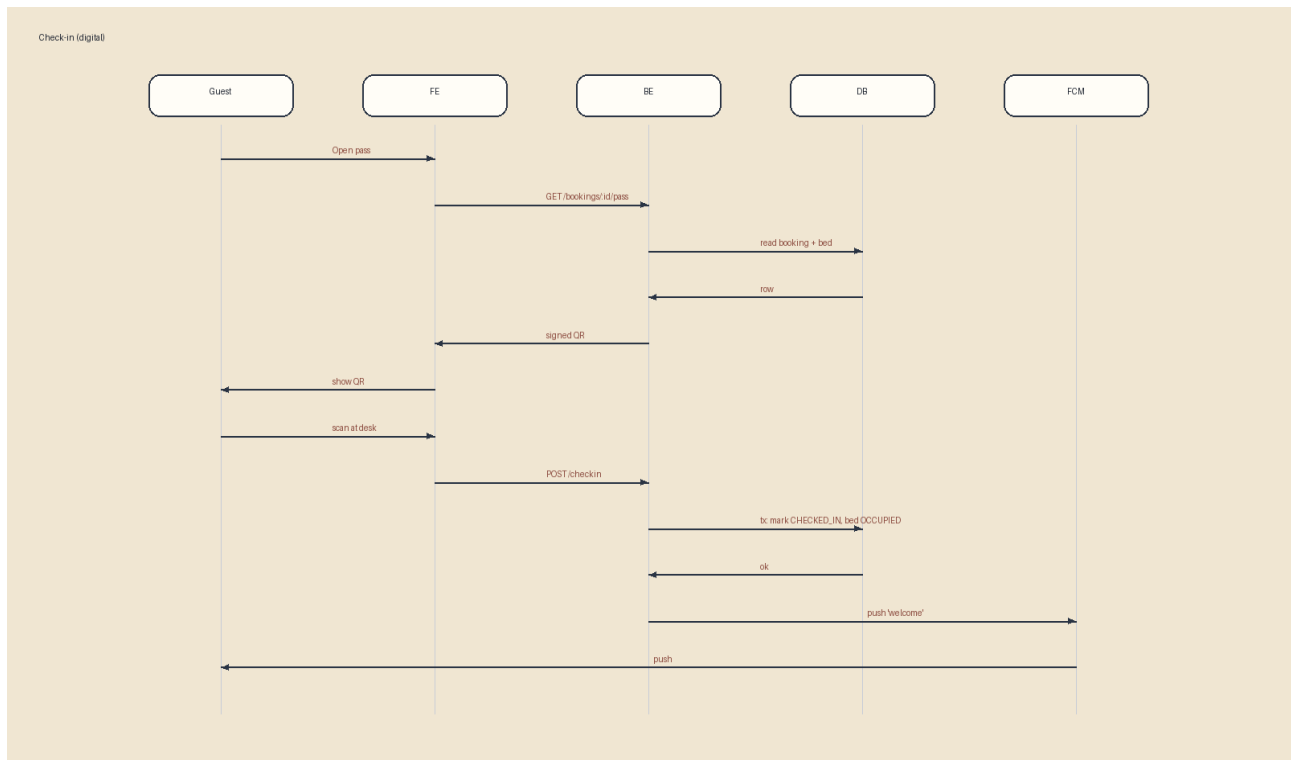
# Architecture



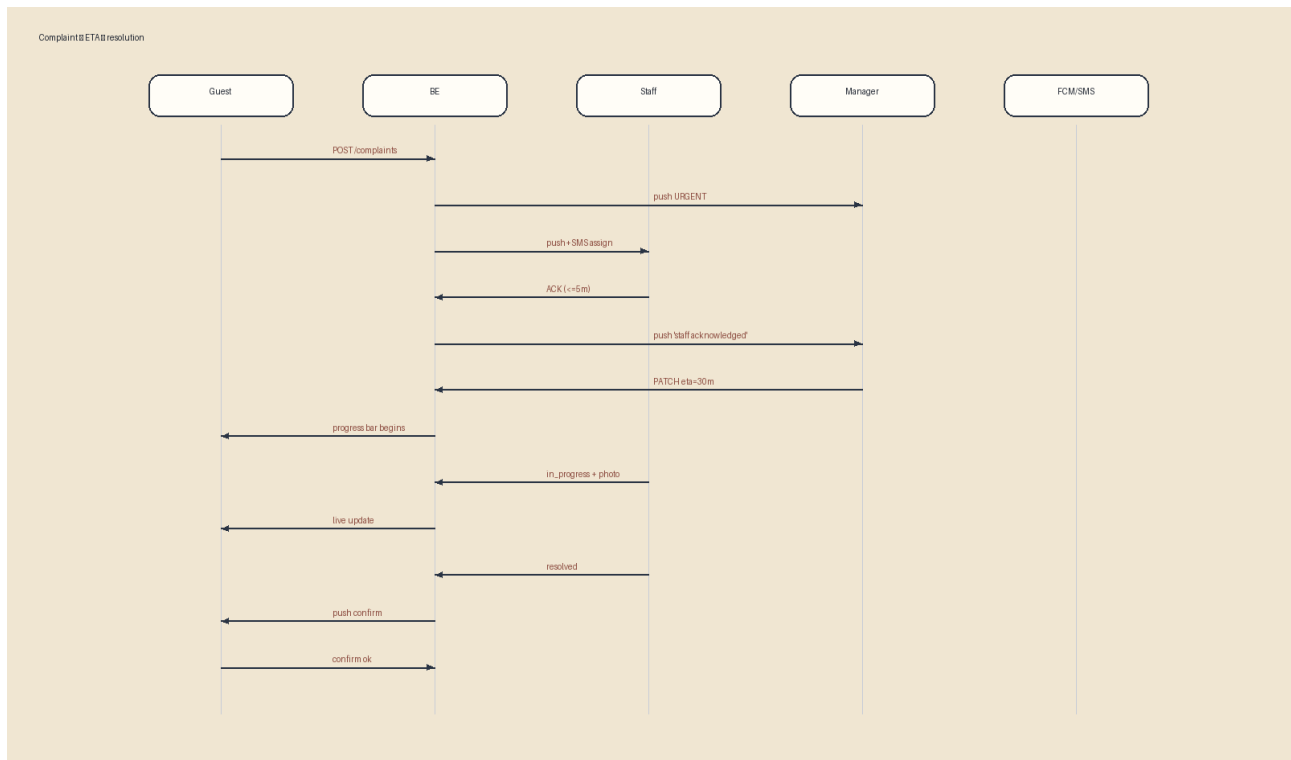
Entity Relationship (abbreviated)



# Seq Checkin



# Seq Complaint Eta



# Seq Kyc Reuse



# Seq Checkout

